

FUTURE INTERNS – CYBERSECURITY TASK

Vulnerability Assessment Report for a Live Website

Prepared by: Levy Gael Ndayisenga

Target: demo.testfire.net

Scope & Objectives

This report presents the results of a vulnerability assessment conducted on a deliberately vulnerable training website. The objective was to identify security weaknesses, classify them by severity, and propose remediation steps. The assessment was performed using OWASP ZAP for web application scanning, Nmap for network exposure analysis, and browser DevTools for header inspection.

The Professional Toolkit

Nmap

Used for network-level reconnaissance to discover open ports and service vulnerabilities.

OWASP ZAP

Employed for passive scanning to identify injection flaws and web vulnerabilities.

DevTools

Used for manual header inspection and client-side session security analysis.

Nmap: Exposure Analysis

Network Exposure

- Identified active services on Port 80.
- Verified the absence of secure redirects (HSTS) at the network layer.
- Mapped the server's footprint for potential entry points.

```
Microsoft Windows [Version 10.0.26200.8328]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\System32>nmap -Pn testphp.vulnweb.com
WARNING: Could not import all necessary Npcap functions. You may need to upgrade to the latest version from https://npcap.com. Resorting to connect() mode -- Nmap may not function completely
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-11 16:14 +0200
Stats: 0:03:21 elapsed; 0 hosts completed (1 up), 1 undergoing Connect Scan
Connect Scan Timing: About 98.50% done; ETC: 16:17 (0:00:03 remaining)
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up.
DNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com
All 1000 scanned ports on testphp.vulnweb.com (44.228.249.3) are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

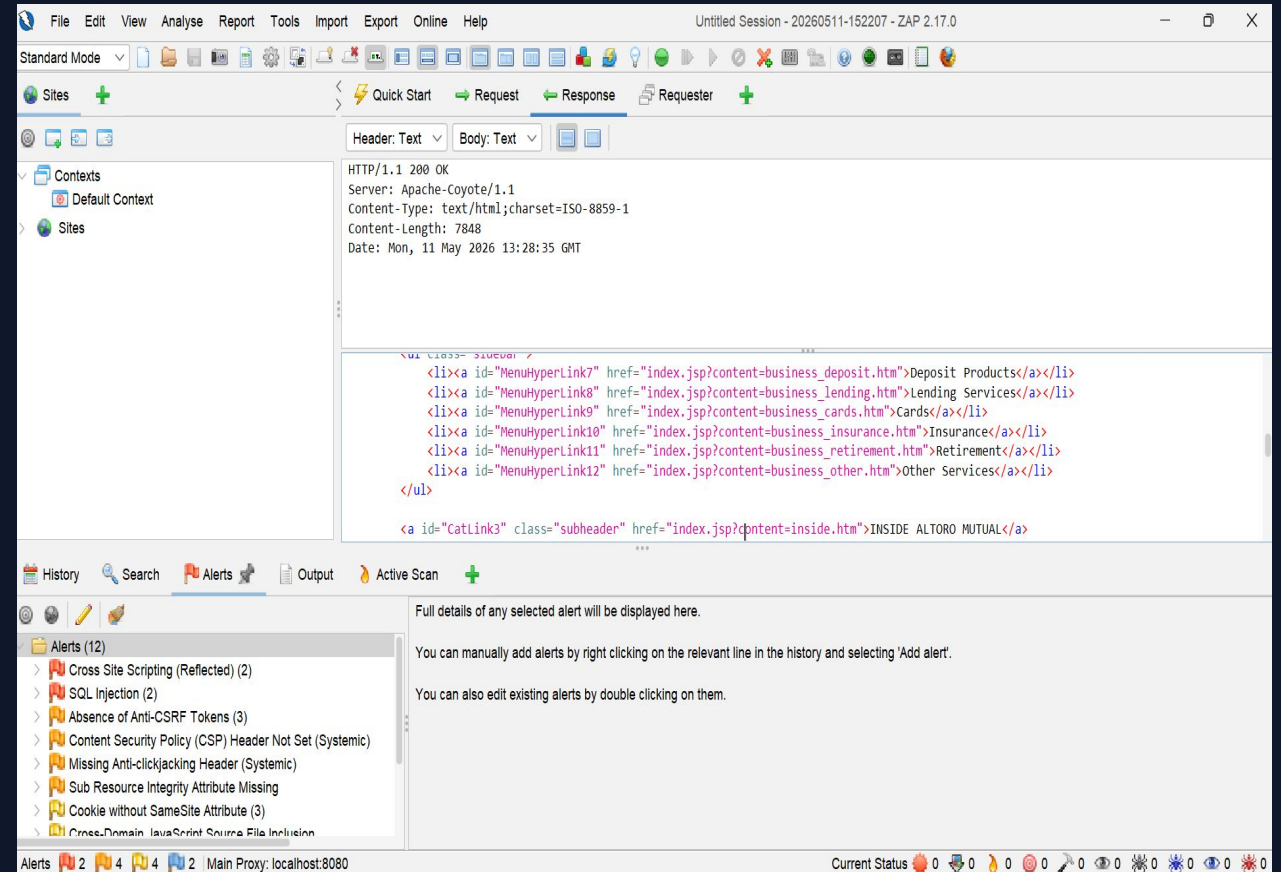
Nmap done: 1 IP address (1 host up) scanned in 204.41 seconds

C:\Windows\System32>
```

OWASP ZAP: Active Alerts

Automated Scan Results

- Detected critical SQL Injection vulnerabilities in search fields.
- Identified Cross-Site Scripting (XSS) risks.
- Flagged missing Anti-Clickjacking headers.



Vulnerability Summary

13

Total Security Alerts

Risk Density

The high density of alerts indicates a critical need for server hardening. The vulnerabilities discovered range from simple information disclosure to high-impact database access risks.

Primary Concern: Input sanitization is nearly non-existent on the test domain.

Risk Classification

High Risks

SQL Injection: Directly impacts database confidentiality and integrity.

XSS: Allows for session hijacking and user impersonation.

Medium Risks

Header Gaps: Missing HSTS and CSP headers leave users vulnerable to browser-level attacks.

Cookie Flags: Insecure session handling.

Information Disclosure

Server Version Leak

During the DevTools audit, the server disclosed its version:

Apache-Coyote/1.1.

Impact: Attackers use this to identify unpatched CVEs specific to the software version.

Name	✕	Headers	Preview	Response	Initiator	>>
index.jsp		▼ General				
style.css						
logo.gif						
header_pic.jpg						
pf_lock.gif						
home1.jpg						
home2.jpg						
home3.jpg						
gradient.jpg		▼ Response headers		☐ Raw		
		Content-Type		text/html; charset=ISO-8859-1		
		Date		Wed, 13 May 2026 10:47:37 GMT		
		Server		Apache-Coyote/1.1		
		Transfer-Encoding		chunked		

Audit: Missing Headers

Security Header	Status	Impact
Strict-Transport-Security	MISSING	Insecure HTTP traffic allowed.
Content-Security-Policy	MISSING	High risk of XSS execution.
X-Frame-Options	MISSING	Vulnerable to Clickjacking.

Session Security



Insecure Cookie Flags

The **Application Tab** review found that session cookies were missing the `HttpOnly` and `Secure` attributes.

Business Impact: User login sessions can be easily stolen by attackers using simple scripts or network sniffing.

Remediation Roadmap

Phase 2: Validation

Implement server-side input sanitization for all forms.

Phase 4: Obfuscation

Disable server version disclosure in response headers.

Phase 1: Encryption

Enforce HTTPS and enable HSTS security headers.

Phase 3: Hardening

Add CSP and Secure cookie flags across the domain.

Thank you